

SOFTWARE REQUIREMENTS SPECIFICATION
SECURITY REQUIREMENTS DOCUMENT (SRS-Sec)

Sistem Booking Hotel

Secure Software Engineering · Teknik Informatika · Universitas Palangka Raya

1. PENDAHULUAN

Dokumen Software Requirements Specification – Security (SRS-Security) ini disusun untuk mendefinisikan seluruh persyaratan keamanan sistem yang wajib dipenuhi dalam pengembangan Sistem Booking Hotel. Dokumen ini menjadi acuan resmi bagi tim pengembang, arsitek sistem, tim QA, dan pemangku kepentingan teknis dalam memastikan sistem dibangun dengan standar keamanan yang memadai.

Tujuan utama dokumen ini adalah:

- Mendefinisikan persyaratan keamanan fungsional dan non-fungsional sistem booking hotel.
- Menetapkan kebijakan autentikasi, otorisasi, dan manajemen sesi pengguna.
- Menjamin kerahasiaan, integritas, dan ketersediaan (CIA Triad) data tamu dan transaksi hotel.
- Memberikan panduan keamanan untuk komunikasi data, enkripsi, dan penyimpanan informasi sensitif.
- Memastikan kepatuhan terhadap regulasi perlindungan data yang berlaku.

2. Ruang Lingkup

Persyaratan keamanan dalam dokumen ini mencakup seluruh komponen Sistem Booking Hotel, meliputi:

- Aplikasi web dan mobile untuk tamu (Guest Portal)
- Panel administrasi internal hotel (Admin Dashboard)
- API backend dan layanan integrasi pihak ketiga (payment gateway, OTA)
- Basis data dan sistem penyimpanan data
- Infrastruktur server, jaringan, dan cloud
- Modul pembayaran dan pengelolaan data kartu kredit tamu

3. Definisi dan Singkatan

Istilah / Singkatan	Definisi
SRS	Software Requirements Specification – Spesifikasi Kebutuhan Perangkat Lunak
CIA Triad	Confidentiality, Integrity, Availability – tiga pilar utama keamanan informasi
MFA	Multi-Factor Authentication – autentikasi menggunakan lebih dari satu faktor verifikasi
RBAC	Role-Based Access Control – kontrol akses berbasis peran pengguna
TLS	Transport Layer Security – protokol enkripsi komunikasi jaringan
AES	Advanced Encryption Standard – standar enkripsi simetris
PCI-DSS	Payment Card Industry Data Security Standard – standar keamanan data kartu pembayaran
OWASP	Open Web Application Security Project – komunitas dan panduan keamanan aplikasi web
WAF	Web Application Firewall – firewall yang melindungi aplikasi web dari serangan
JWT	JSON Web Token – standar token untuk autentikasi berbasis klaim
OTA	Online Travel Agent – mitra agen perjalanan online
SIEM	Security Information and Event Management – sistem manajemen log keamanan
2FA	Two-Factor Authentication – autentikasi dua faktor
SQL Injection	Teknik serangan yang menyisipkan kode SQL berbahaya ke dalam input pengguna
XSS	Cross-Site Scripting – serangan injeksi skrip berbahaya pada aplikasi web
CSRF	Cross-Site Request Forgery – serangan pemalsuan permintaan lintas situs

4. Referensi

- OWASP Top 10 Web Application Security Risks 2021
- NIST Special Publication 800-63B (Digital Identity Guidelines)
- PCI DSS v3.2.1 (Payment Card Industry Data Security Standard)

5. Deskripsi Sistem

Sistem Booking Hotel adalah platform digital terintegrasi yang memungkinkan tamu melakukan reservasi kamar secara online, mengelola check-in/check-out, melakukan pembayaran, serta berinteraksi dengan layanan hotel. Sistem ini terdiri dari aplikasi web dan mobile untuk tamu (Guest Portal), panel administrasi internal hotel (Admin Dashboard), RESTful API backend yang mengelola logika bisnis, serta integrasi dengan layanan eksternal seperti payment gateway dan OTA (Online Travel Agent).

Komponen utama sistem meliputi:

- Frontend: Aplikasi web berbasis browser dan aplikasi mobile (iOS/Android)
- Backend: RESTful API yang mengelola logika bisnis dan integrasi layanan
- Database: Sistem manajemen basis data relasional untuk data tamu, reservasi, dan transaksi
- Integrasi Eksternal: Payment gateway, sistem OTA, dan layanan notifikasi

6. DATA FLOW DIAGRAM (DFD)

DFD digunakan untuk memetakan aliran data, proses, entitas eksternal, dan data store. Ini adalah dasar dari trust boundary dan threat model.

A. DFD Level 0 (Diagram Konteks)

DFD LEVEL 0 (GAMBARAN UMUM SISTEM)

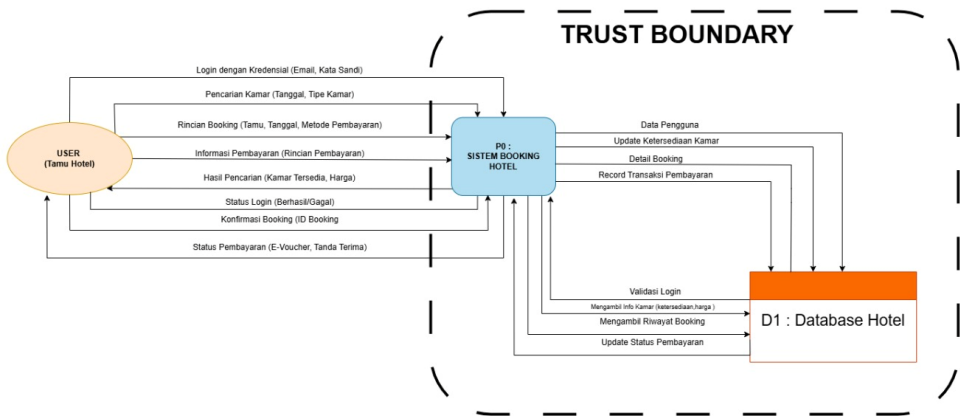


Diagram Konteks (DFD Level 0) menggambarkan sistem secara keseluruhan sebagai satu proses tunggal (Sistem Booking Hotel). Diagram ini menunjukkan interaksi antara sistem dengan entitas eksternal yang berinteraksi langsung dengan sistem. Entitas eksternal tidak memiliki akses ke dalam proses internal sistem.

Entitas Eksternal dalam DFD Level 0:

- Tamu (Guest) → Memberikan input data reservasi, pembayaran, dan permintaan layanan. Menerima output berupa konfirmasi booking, invoice, dan notifikasi.
- Front Desk Staff → Memasukkan data check-in/check-out, reservasi walk-in. Menerima status kamar dan reservasi.
- Hotel Manager → Mengakses laporan dan manajemen kamar. Tidak terlibat langsung dalam transaksi harian.
- Super Admin / IT → Melakukan konfigurasi sistem, monitoring keamanan, dan manajemen pengguna.
- Payment Gateway → Menerima data pembayaran terenkripsi, mengembalikan status transaksi (success/failed).
- OTA (Online Travel Agent) → Mengirim data reservasi dari pihak ketiga, menerima konfirmasi ketersediaan kamar.

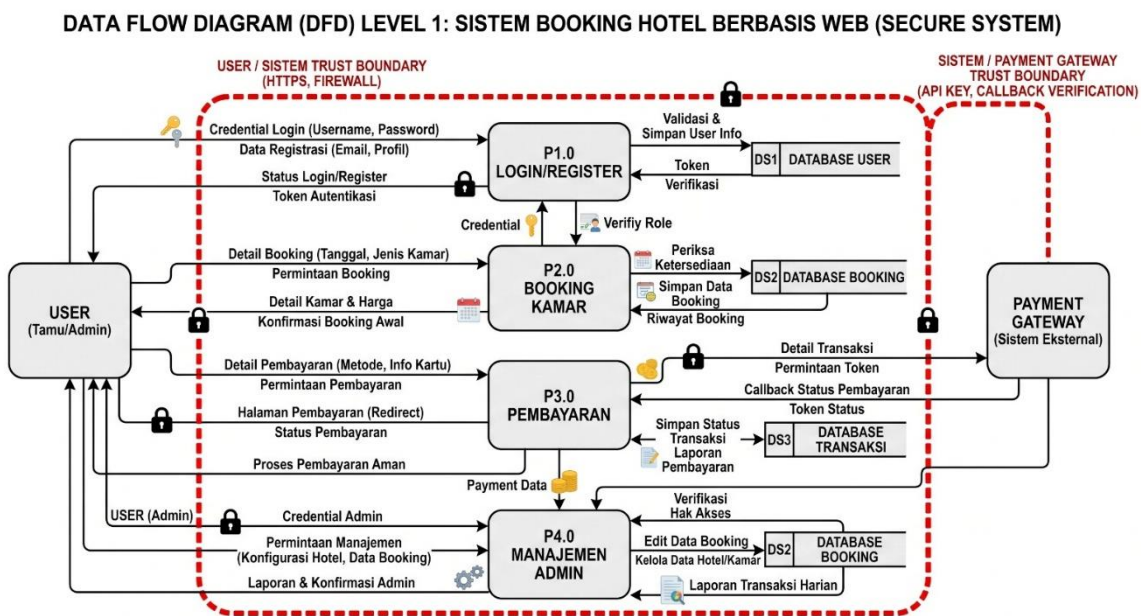
Arus Data Utama (Melewati Trust Boundary):

Data reservasi, pembayaran, konfirmasi, laporan, notifikasi, dan data konfigurasi.

Keamanan:

Semua arus data yang masuk/keluar sistem harus melalui validasi autentikasi, otorisasi, dan enkripsi (TLS 1.2+).

B. DFD Level 1 (Rincian Proses Utama)



DFD Level 1 memecah proses tunggal pada diagram konteks menjadi proses-proses utama yang lebih rinci. Setiap proses mewakili fungsi bisnis spesifik dalam sistem.

Proses Utama dalam DFD Level 1:

Proses 1: Manajemen Reservasi

- Input: Data reservasi dari tamu, front desk, OTA
- Output: Konfirmasi reservasi, update ketersediaan kamar
- Penyimpanan: Data reservasi, data kamar

Proses 2: Manajemen Pembayaran

- Input: Data pembayaran terenkripsi dari tamu
- Output: Status transaksi ke payment gateway dan ke tamu
- Penyimpanan: Log transaksi (tanpa data kartu kredit)

Proses 3: Manajemen Check-in/Check-out

- Input: Verifikasi identitas, status kamar
- Output: Aktivasi kunci digital, invoice
- Penyimpanan: Data tamu, data reservasi aktif

Proses 4: Manajemen Laporan & Monitoring

- Input: Data transaksi, okupansi, log sistem
- Output: Laporan ke manajer, alert keamanan ke admin
- Penyimpanan: Log sistem, data historis

Proses 5: Integrasi OTA & Gateway

- Input: Data dari OTA, respons dari payment gateway
- Output: Konfirmasi ke OTA, token pembayaran
- Penyimpanan: Log integrasi

Arus Data Antar Proses:

Setiap proses berkomunikasi melalui mekanisme API internal yang juga tunduk pada kebijakan keamanan (autentikasi service-to-service, validasi input, logging).

7. MODEL ANCAMAN (THREAT MODEL) - BERDASARKAN STRIDE

STRIDE adalah metodologi pemodelan ancaman yang digunakan untuk mengidentifikasi potensi ancaman keamanan pada setiap komponen sistem (entitas eksternal, proses, data store, aliran data). Setiap huruf dalam STRIDE mewakili jenis ancaman berbeda.

ID	Ancaman	STRIDE	Komponen Terkait	Dampak
T1	Pencurian kredensial tamu melalui phishing	Spoofing	Guest Portal	Pengambilalihan akun
T2	Manipulasi data reservasi oleh staff tidak sah	Tampering	Admin Dashboard	Reservasi fiktif
T3	Penyangkalan transaksi pembayaran oleh tamu	Repudiation	Payment Module	Kerugian hotel
T4	Ekspos data pribadi tamu di log sistem	Info Disclosure	Database Server	Pelanggaran privasi
T5	Serangan DoS pada API gateway	DoS	Backend API	Layanan tidak tersedia
T6	Staff meningkatkan hak akses ke admin	Elevation of Privilege	RBAC System	Penyalahgunaan sistem
T7	Injeksi SQL pada form pencarian kamar	Tampering	Database Server	Kebocoran data
T8	XSS pada halaman ulasan tamu	Spoofing	Guest Portal	Eksekusi skrip jahat
T9	Pembajakan sesi setelah login	Spoofing	Session Manager	Akses tidak sah

T10	Pemalsuan notifikasi pembayaran dari gateway	Spoofing	Payment Gateway	Pembayaran fiktif
T11	Penyadapan data antara mobile app dan API	Info Disclosure	Network Channel	Pencurian data sensitif
T12	Penghapusan log audit oleh intruder	Tampering	SIEM / Log	Hilangnya jejak forensik
T13	Token JWT tidak divalidasi dengan benar	Elevation of Privilege	Auth Service	Akses tanpa otorisasi
T14	Data cadangan tidak dienkripsi	Info Disclosure	Backup Storage	Kebocoran data historis
T15	CSRF pada form ubah password	Repudiation	Guest Portal	Ubah password tanpa izin

Tabel Ancaman STRIDE (Minimal 15 Ancaman)

8. ATTACK TREE ANALYSIS

Analisis ini mendokumentasikan skenario serangan untuk dua ancaman dengan risiko KRITIS: (1) Pengambilalihan Akun Tamu/Admin, (2) Manipulasi Pembayaran.

a. Attack Tree 1: Mengambil Alih Akun (Account Takeover)

Root Goal: Penyerang berhasil mengakses akun tamu atau admin

OR 1: Mencuri kredensial

- AND 1.1: Phishing (email palsu, halaman login tiruan)
- AND 1.2: Keylogging (malware di perangkat tamu)
- AND 1.3: Reuse password dari data breach lain

OR 2: Membajak sesi aktif

- AND 2.1: Mencuri token JWT dari network (jika tidak pakai TLS)
- AND 2.2: XSS mencuri cookie session
- AND 2.3: Session fixation (menetapkan session ID sebelum login)

OR 3: Eksploitasi kelemahan sistem

- AND 3.1: SQL injection di form login (bypass password)
- AND 3.2: Endpoint reset password yang lemah (tebak token)
- AND 3.3: Akun default admin tidak diganti

Mitigasi:

- MFA wajib untuk admin dan opsional untuk tamu
- TLS 1.3 untuk semua komunikasi
- Token JWT short expiration + refresh token
- Rate limiting pada endpoint login/reset password
- Logging percobaan login gagal

b. Attack Tree 2: Manipulasi Transaksi Pembayaran

Root Goal: Penyerang mengubah jumlah bayar atau status pembayaran

OR 1: Intercept dan modifikasi request pembayaran

- AND 1.1: Man-in-the-Middle (jika tanpa TLS)
- AND 1.2: Memodifikasi parameter amount dalam request API

OR 2: Eksploitasi integrasi payment gateway

- AND 2.1: Mengulang (replay) notifikasi sukses dari gateway
- AND 2.2: Memalsukan callback URL untuk mengirim sukses palsu
- AND 2.3: Mencuri API key antara hotel dan gateway

OR 3: Manipulasi data di database langsung

- AND 3.1: SQL injection mengubah status payment
- AND 3.2: Akses tidak sah ke database (credential leak)

OR 4: Eksploitasi web frontend

- AND 4.1: Inspect element mengubah nilai amount client-side
- AND 4.2: CSRF mengirim request pembayaran ulang

Mitigasi:

- Validasi jumlah pembayaran di backend (tidak percaya client)
- Signature pada setiap notifikasi webhook dari gateway
- Token anti-CSRF pada setiap form pembayaran
- Database hanya bisa diupdate melalui stored procedure atau ORM yang aman
- Audit log semua perubahan status pembayaran

9. Identifikasi Aset Kritis menyesuaikan dfd

Berdasarkan DFD Level 0 dan Level 1, berikut adalah aset-aset kritis dalam Sistem Booking Hotel yang wajib dilindungi untuk menjaga kerahasiaan, integritas, dan ketersediaan (CIA Triad):

ID Aset	Nama Aset	Lokasi (DFD)	Tingkat Risiko	Alasan Kritis
A-001	Kredensial Login (Username, Password, Token)	Proses Autentikasi, Database Pengguna	KRITIS	Jika bocor, penyerang dapat mengambil alih akun tamu atau admin
A-002	Data Pribadi Tamu (Nama, KTP, Passport, Alamat, No. Telepon, Email)	Data Store Tamu, Proses Reservasi	KRITIS	Dilindungi regulasi privasi (GDPR/PDPL); kebocoran menyebabkan denda dan hilangnya kepercayaan
A-003	Data Pembayaran (Transaksi, Status, Referensi)	Proses Pembayaran, Data Store Transaksi	KRITIS	Menjadi target utama manipulasi pembayaran; terkait langsung dengan pendapatan hotel
A-004	Data Kartu Kredit/Debit (PAN, CVV, Expiry)	TIDAK DISIMPAN — Hanya lewat Payment Gateway	KRITIS	Wajib patuh PCI-DSS; sistem hotel dilarang menyimpan data ini
A-005	API Keys & Secret Keys	Proses Integrasi,	KRITIS	Kebocoran memungkinkan penyerang

	(Payment Gateway, OTA)	Konfigurasi Sistem		memalsukan transaksi atau mengambil data
A-006	Log Sistem & Audit Trail	Data Store Log, Proses Monitoring	TINGGI	Penting untuk forensik dan deteksi insiden; jika dihapus atau dirusak, investigasi gagal
A-007	Data Reservasi Aktif (Kamar, Tanggal, Harga)	Data Store Reservasi, Proses Check-in/out	TINGGI	Manipulasi menyebabkan kerugian operasional (double booking, harga salah)
A-008	Konfigurasi RBAC (Peran dan Hak Akses)	Data Store Konfigurasi, Proses Otorisasi	TINGGI	Jika diubah, staff bisa mendapatkan hak akses tidak sah
A-009	Session Token (JWT / Cookie Session)	Proses Manajemen Sesi	TINGGI	Pembajakan sesi memungkinkan akses tanpa kredensial
A-010	Laporan Keuangan & Okupansi	Data Store Laporan, Proses Laporan	TINGGI	Informasi bisnis sensitif; kebocoran merugikan kompetitif
A-011	Kunci Digital Kamar (untuk Mobile Check-in)	Proses Check-in/out, Data Store Sementara	TINGGI	Manipulasi memungkinkan akses fisik ke kamar tamu

A-012	Data Integrasi OTA (Booking dari Agoda, Traveloka, dll)	Proses Integrasi OTA, Data Store Reservasi	SEDANG	Kesalahan sinkronisasi menyebabkan overbooking
A-013	Source Code Aplikasi	Environment Development, Repository	SEDANG	Ekspos source code dapat mengungkap celah keamanan
A-014	Backup Database	Storage Backup (terpisah)	KRITIS	Backup tidak terenkripsi menjadi target mudah pencurian data massal

10. Security Requirements

Persyaratan keamanan berikut ditulis dalam format terukur dan verifiable menggunakan kata kunci HARUS / TIDAK BOLEH / SEBAIKNYA / DAPAT sesuai standar penulisan security requirement.

A. Persyaratan Autentikasi dan Manajemen Sesi :

ID	Requirement	Komponen DFD	Ancaman STRIDE	Verifikasi
AUTH-01	Sistem HARUS menerapkan kebijakan password minimal 8 karakter, mengandung huruf besar, huruf kecil, angka, dan simbol	Proses Autentikasi	Spoofing (T1)	Uji coba pembuatan akun dengan password lemah harus ditolak
AUTH-02	Sistem HARUS mengimplementasikan MFA (Multi-Factor Authentication) untuk semua akun Super	Proses Autentikasi	Spoofing (T1, T9)	Verifikasi dengan mencoba login admin tanpa MFA harus gagal

	Admin dan Hotel Manager			
AUTH-03	Sistem HARUS mengunci akun sementara selama 15 menit setelah 5 kali percobaan login gagal berurutan	Proses Autentikasi	DoS, Spoofing (T1)	Simulasi 5x login gagal, akun terkunci sesuai durasi
AUTH-04	Session token (JWT) HARUS memiliki masa berlaku maksimal 2 jam untuk tamu dan 30 menit untuk admin	Proses Manajemen Sesi	Spoofing (T9)	Inspeksi token claim exp harus sesuai ketentuan
AUTH-05	Sistem TIDAK BOLEH menyimpan password dalam bentuk plaintext. Password HARUS di-hash menggunakan bcrypt (cost factor $\geq$ 10) atau argon2	Database Pengguna	Info Disclosure (T4)	Periksa skema database; tidak ditemukan kolom password plaintext
AUTH-06	Fitur "Lupa Password" HARUS mengirimkan token sekali pakai (expired dalam 15 menit) ke email terdaftar, TIDAK BOLEH mengirim password lama	Proses Manajemen Akun	Elevation of Privilege (T6, T13)	Uji coba reset password; token tidak dapat digunakan ulang setelah 15 menit

B. Persyaratan Otorisasi dan RBAC :

ID	Requirement	Komponen DFD	Ancaman STRIDE	Verifikasi
RBAC-01	Sistem HARUS menerapkan Role-Based	Proses Otorisasi	Elevation of Privilege (T6)	Uji coba akses endpoint dengan setiap

	Access Control (RBAC) dengan minimal 4 peran: Tamu, Front Desk Staff, Hotel Manager, Super Admin			role; hanya yang diotorisasi yang berhasil
RBAC-02	Front Desk Staff TIDAK BOLEH mengakses halaman laporan keuangan atau mengubah konfigurasi sistem	Admin Dashboard, Proses Laporan	Elevation of Privilege (T6)	Login sebagai Front Desk Staff, coba akses URL laporan keuangan → harus ditolak (HTTP 403)
RBAC-03	Super Admin HARUS menggunakan akun terpisah untuk aktivitas sehari-hari (non-privileged) dan hanya menggunakan akun admin untuk keperluan konfigurasi dengan MFA	Proses Otorisasi	Elevation of Privilege (T6)	Audit log menunjukkan penggunaan akun privileged hanya untuk aksi tertentu
RBAC-04	Setiap perubahan pada RBAC (tambah/hapus role, ubah	Data Store Log, Proses Monitoring	Repudiation (T3)	Uji coba ubah role, cek log apakah ada entri lengkap

	permission) HARUS dicatat dalam audit log beserta identitas admin yang melakukan perubahan			
--	---	--	--	--

C. Persyaratan Keamanan Data (CIA Triad) :

ID	Requirement	Komponen DFD	Ancaman STRIDE	Verifikasi
DATA-01	Data pribadi tamu (nama, alamat, nomor telepon, email, dokumen identitas) HARUS dienkripsi saat disimpan di database menggunakan AES-256	Database Server (Data Store Tamu)	Info Disclosure (T4, T14)	Periksa isi database secara langsung; data harus dalam bentuk ciphertext
DATA-02	Sistem TIDAK BOLEH menyimpan data CVV atau track data kartu kredit. Data kartu hanya dilewatkan langsung ke Payment Gateway	Proses Pembayaran	Info Disclosure (T4)	Inspeksi skema database; tidak ada kolom CVV, PAN, atau track data
DATA-03	Semua komunikasi antara client	Semua aliran data melewati TB1, TB2	Info Disclosure (T11)	Gunakan tools seperti SSL Labs atau

	(web/mobile) dan server HARUS menggunakan TLS 1.2 atau lebih tinggi			Wireshark untuk memverifikasi tidak ada plaintext HTTP
DATA-04	Backup database HARUS dienkripsi menggunakan AES-256 dengan kunci yang disimpan terpisah dari data backup	Backup Storage (A-014)	Info Disclosure (T14)	Coba akses file backup secara langsung; harus tidak dapat dibaca tanpa kunci
DATA-05	Data sensitif (password, API keys, secret keys) TIDAK BOLEH muncul dalam log sistem atau response error	Data Store Log	Info Disclosure (T4)	Simulasi error; periksa log dan response apakah mengandung informasi sensitif

D. Persyaratan Keamanan Input dan Validasi :

ID	Requirement	Komponen DFD	Ancaman STRIDE	Verifikasi
INPUT-01	Semua input pengguna HARUS divalidasi di sisi server (backend), TIDAK BOLEH hanya mengandalkan	Semua Proses yang menerima input (1,2,3,5)	Tampering (T2, T7)	Uji coba input berbahaya (SQL injection, XSS) via request langsung ke API tanpa melewati frontend

	validasi client-side			
INPUT-02	Sistem HARUS menggunakan parameterized query atau ORM untuk semua operasi database untuk mencegah SQL Injection	Proses Reservasi, Proses Pembayaran, Database Server	Tampering (T7)	Uji coba input ' OR '1'='1 pada form pencarian; tidak menghasilkan data tidak sah
INPUT-03	Sistem HARUS menerapkan output encoding untuk mencegah XSS (Cross-Site Scripting) pada halaman yang menampilkan data pengguna	Guest Portal (Frontend)	Spoofing (T8)	Uji coba input <script>alert('XSS')</script>; skrip tidak dieksekusi saat ditampilkan
INPUT-04	Setiap form yang mengubah data (ubah password, pembayaran, reservasi) HARUS dilindungi dengan token anti-CSRF	Guest Portal, Admin Dashboard	Repudiation, Tampering (T15)	Uji coba serangan CSRF menggunakan tool seperti Burp Suite; request tanpa token ditolak

E. Persyaratan Keamanan Integrasi (Payment Gateway & OTA) :

ID	Requirement	Komponen DFD	Ancaman STRIDE	Verifikasi
INT-01	Setiap request dari Payment Gateway ke sistem hotel HARUS diverifikasi signature-nya. Sistem TIDAK BOLEH memproses notifikasi tanpa signature yang valid	Proses Integrasi Gateway	Spoofing (T10)	Simulasi callback palsu tanpa signature; harus ditolak
INT-02	API Key untuk integrasi dengan OTA dan Payment Gateway HARUS disimpan dalam secure vault (misal: AWS Secrets Manager, HashiCorp Vault), TIDAK BOLEH	Environment Production, Proses Integrasi	Info Disclosure (T4)	Periksa repository code; tidak ditemukan API key dalam bentuk hardcoded

	hardcoded di source code			
INT-03	Sistem HARUS melakukan whitelist IP address untuk callback dari Payment Gateway. Hanya request dari IP yang terdaftar yang diproses	Proses Integrasi Gateway	Spoofing (T10)	Uji coba callback dari IP tidak terdaftar; harus ditolak
INT-04	Jumlah pembayaran HARUS divalidasi ulang di sisi backend. Sistem TIDAK BOLEH mempercayai nilai amount yang dikirim dari client	Proses Pembayaran	Tampering (T2)	Intercept request pembayaran, ubah amount menjadi 0 atau 1; backend harus menolak

F. Persyaratan Logging, Monitoring, dan Audit :

ID	Requirement	Komponen DFD	Ancaman STRIDE	Verifikasi
LOG-01	Sistem HARUS mencatat semua event keamanan berikut dalam audit log: login (berhasil/gagal), perubahan password, akses data sensitif,	Data Store Log, Proses Monitoring	Repudiation (T3)	Lakukan aksi-aksi tersebut, verifikasi log tercatat dengan timestamp dan identitas pengguna

	perubahan RBAC, transaksi pembayaran			
LOG-02	Log TIDAK BOLEH dapat diubah atau dihapus oleh pengguna biasa (termasuk Front Desk Staff dan Hotel Manager). Hanya Super Admin yang dapat mengakses log, itupun dengan mode read-only	Data Store Log	Tampering (T12)	Login sebagai Front Desk Staff, coba hapus log; harus gagal
LOG-03	Sistem HARUS mengirimkan alert real-time ke Super Admin jika terjadi: 5+ login gagal dalam 1 menit, akses ke endpoint sensitif di luar jam kerja, perubahan konfigurasi keamanan	Proses Monitoring	DoS, Elevation of Privilege	Simulasi percobaan brute force; alert harus terkirim dalam waktu <1 menit
LOG-04	Sistem HARUS menyimpan log minimal untuk 90 hari ke	Data Store Log	Info Disclosure (T4)	Periksa kebijakan retensi dan verifikasi log

	belakang dan secara periodik mengarsipkan ke storage terpisah yang juga dienkripsi			>90 hari masih tersedia dalam archive
--	--	--	--	---------------------------------------

G. Persyaratan Keamanan Infrastruktur :

ID	Requirement	Komponen DFD	Ancaman STRIDE	Verifikasi
INFRA-01	Sistem HARUS dilindungi oleh Web Application Firewall (WAF) yang dikonfigurasi untuk memblokir serangan umum (SQLi, XSS, path traversal)	Antara Internet dan Web Server	Tampering (T7, T8), DoS (T5)	Uji coba serangan SQLi melalui WAF; request harus diblokir (HTTP 403)
INFRA-02	Sistem HARUS menerapkan rate limiting pada endpoint publik: maksimal 100 request per IP per menit untuk guest endpoints, dan 30 request per menit untuk endpoint autentikasi	API Gateway	DoS (T5), Brute Force	Simulasi 150 request cepat dari IP yang sama; beberapa request harus ditolak dengan code 429
INFRA-03	Akses ke production	Trust Boundary TB4	Elevation of Privilege (T6)	Verifikasi tidak ada akses SSH

	server dari luar jaringan internal HARUS melalui jump server / bastion host dengan MFA			langsung ke production server dari internet
INFRA-04	Semua software dependencies (library, package) HARUS dipindai kerentanannya setiap minggu menggunakan SCA (Software Composition Analysis) tool	Environment Development & Production	Semua ancaman	Tunjukkan laporan scan SCA terbaru dengan status tidak ada critical vulnerability

H. Persyaratan Kepatuhan dan Dokumentasi :

ID	Requirement	Komponen DFD	Ancaman STRIDE	Verifikasi
COMP-01	Sistem HARUS mematuhi persyaratan PCI-DSS untuk semua	Proses Pembayaran, Integrasi Gateway	Semua ancaman payment	Lakukan self-assessment PCI-DSS SAQ secara berkala

	komponen yang menangani atau mempengaruhi data pembayaran			
COMP-02	Sistem HARUS memiliki prosedur respons insiden yang terdokumentasi dan diuji minimal setahun sekali	Seluruh sistem	Semua ancaman	Tinjau dokumen prosedur respons insiden dan bukti uji coba (tabletop exercise)
COMP-03	Pengembang HARUS menjalani pelatihan keamanan aplikasi (OWASP Top 10, secure coding) minimal setahun sekali	Tim Pengembang	Semua ancaman	Tunjukkan sertifikat atau bukti pelatihan untuk setiap developer

11. Definisi Stakeholder & Trust Boundary

a. Definisi Stakeholder

Dalam pengembangan dan pengoperasian Sistem Booking Hotel, terdapat beberapa stakeholder dengan peran dan kepentingan keamanan yang berbeda. Tamu hotel (terdaftar) merupakan pengguna akhir sistem yang memiliki kepentingan utama pada kerahasiaan data pribadi serta keamanan transaksi pembayaran mereka. Tamu anonim adalah pengunjung yang belum melakukan login dan hanya diberikan akses terbatas pada informasi publik seperti ketersediaan kamar dan harga, tanpa dapat mengakses data pribadi atau melakukan reservasi. Front desk staff berperan sebagai operator operasional hotel yang memiliki akses ke data reservasi serta proses check-in dan check-out, namun tidak diperbolehkan mengakses laporan keuangan atau data sensitif lainnya. Hotel manager bertindak sebagai pengawas

operasional hotel dengan kewenangan mengakses laporan manajemen dan data okupansi, tetapi tidak dapat mengubah konfigurasi sistem keamanan atau memberikan hak akses istimewa. Super admin / IT merupakan administrator sistem yang memiliki akses penuh terhadap seluruh komponen sistem, namun dibebani kewajiban untuk menggunakan autentikasi multifaktor (MFA) serta setiap aksinya wajib terekam dalam audit log untuk menjaga akuntabilitas. Payment gateway adalah layanan pembayaran eksternal yang terintegrasi dengan sistem hotel melalui API terenkripsi; prinsip keamanan yang diterapkan adalah bahwa sistem hotel tidak boleh menyimpan data kartu kredit tamu (seperti PAN, CVV, atau masa berlaku), melainkan hanya meneruskan data terenkripsi ke gateway. Terakhir, tim pengembang bertanggung jawab atas pengembangan dan pengujian sistem, namun akses mereka dibatasi hanya pada lingkungan development dan testing saja, serta dilarang keras mengakses data production untuk mencegah kebocoran data asli tamu hotel. Seluruh stakeholder ini harus dipetakan dalam trust boundary untuk menentukan batas kepercayaan dan mekanisme keamanan yang berlaku pada setiap interaksi mereka dengan sistem.

b. Trust Boundary

Trust boundary adalah batas logis yang memisahkan zona dengan tingkat kepercayaan berbeda. Setiap data yang melintasi trust boundary harus melalui pemeriksaan keamanan ketat (autentikasi, validasi input, dekripsi jika perlu, dan logging).

Trust Boundary dalam Sistem Booking Hotel:

Boundary ID	Antara Zona	Mekanisme Keamanan
TB1	Guest Browser → Web Server (Internet)	TLS 1.3, HSTS, WAF, Rate limiting, Validasi input anti-XSS/SQLi
TB2	Mobile App → API Gateway (Internet)	TLS + Certificate Pinning, Token autentikasi (JWT), Nonce untuk anti-replay
TB3	Internal Staff (Front Desk/Manager) → Admin Panel	VPN atau jaringan internal terenkapsulasi, MFA wajib, Logging akses
TB4	Super Admin → Production Server	Jump server / bastion host, MFA, Session timeout ketat, Audit log semua command
TB5	Backend API → Database Server	Kredensial terpisah per layanan, Enkripsi data sensitif di rest, Query parameterized

TB6	Sistem Hotel → Payment Gateway (Internet)	Mutual TLS (mTLS), Whitelist IP Gateway, Signature pada setiap payload
TB7	Sistem Hotel → OTA (Internet)	API Key + Secret, Enkripsi payload, Logging semua request/response
TB8	Development Environment → Production Data	Tidak ada akses langsung, Gunakan data dummy/anonymized di dev